

SMART CONTRACT SECURITY

# SECURITY ASSESSMENT & REMEDIATION VERIFICATION

Baseline finding closure, executable revalidation, governance controls, principal accounting, LTV enforcement, reserve commitment integrity, and chain-aware asset identity.

17/17

FINDINGS RESOLVED

31/31

CHECKS PASSED

0

OPEN FINDINGS

ASSESSMENT ID  
WCF - SARV - 2026 - 0810

EXECUTIVE CONCLUSION

01 / RESULT

17/17

FINDINGS RESOLVED

31/31

AUTOMATED CHECKS PASSED

0

COMPILER ERRORS / WARNINGS

ASSESSMENT CONCLUSION

The assessed Solidity 0.8.26 build closes all ten baseline findings and seven expanded control findings recorded in this report. Nine historical defect classes were reproduced in StakeBaseline, the corresponding root causes were removed or constrained in the remediated contracts, and every named closure check passed in the isolated chain 31337 environment.

| DECISION RECORD   |          |                                                                      |
|-------------------|----------|----------------------------------------------------------------------|
| CONTROL           | RESULT   | EVIDENCE                                                             |
| Baseline findings | 10       | All mapped to an implemented patch and a named revalidation check    |
| Expanded controls | 7        | Governance, solvency, LTV, reentrancy, pause, PoR, identity, display |
| Compiler          | 0 / 0    | Errors / warnings under optimizer 200 and Shanghai EVM               |
| Status            | Resolved | No open item remains in the exact assessed build                     |

CONCLUSION BOUNDARY

This conclusion covers the source files, compiler settings, artifacts, tests, bytecode hashes, signer roles, and contract addresses enumerated in the report. Custody accounts, complete liabilities, production backend, KYC, mobile/web clients, oracle feeds, bridge security, and operational execution are assessed only where an explicit control is listed.

ASSESSMENT TIMELINE & EVIDENCE CONTROL

02 / CONTROL

| MILESTONE            | DATE       | CONTROLLED IDENTITY                                        |
|----------------------|------------|------------------------------------------------------------|
| Baseline assessment  | 2025-12-22 | Stake.sol / commit 6abbb72e994862c912996b042add26c8c4510c2 |
| Remediation campaign | 2026-08-10 | Nine source files / 31 checks / nine deployed contracts    |
| Document release     | 2026-08-10 | Version 3.0 / assessment ID WCF-SARV-2026-0810             |

BASELINE EVIDENCE

| FIELD           | VALUE                                                            |
|-----------------|------------------------------------------------------------------|
| Commit          | 6abbb72e994862c912996b042add26c8c4510c2                          |
| Source          | src/Stake.sol                                                    |
| Source SHA-256  | 983b98a6063225e82fc7d282ed855ddc366b63be3bb2b833ec58c869182edf7e |
| Baseline status | 9 findings + 1 optimization acknowledged                         |

REMEDIATION EVIDENCE

| FIELD         | VALUE                                                                 |
|---------------|-----------------------------------------------------------------------|
| Compiler      | 0.8.26+commit.8a97fa7a.Emscripten.clang                               |
| Configuration | Optimizer enabled / 200 runs / Shanghai EVM                           |
| Environment   | Chain 31337 / block 82 / Whale CeFi isolated revalidation environment |
| Results       | 31/31 passed / 0 failed                                               |

SCOPE & ASSESSED COMPONENTS

03 / SCOPE

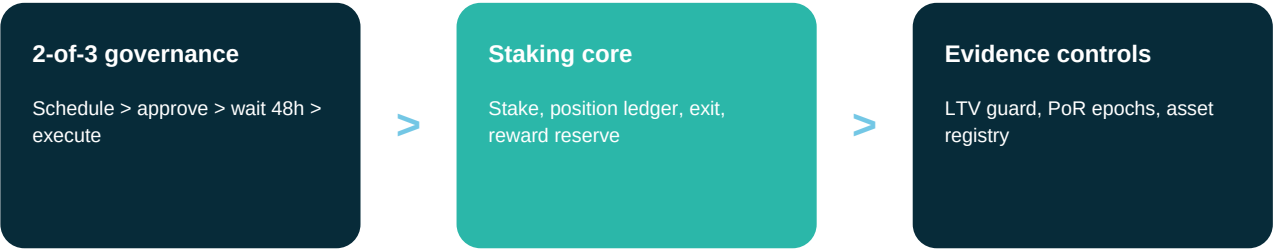
| COMPONENT                              | ROLE                         | SECURITY PROPERTY                               |
|----------------------------------------|------------------------------|-------------------------------------------------|
| StakeBaseline.sol                      | Baseline defect reproduction | Historical logic and accounting failure modes   |
| WhaleCeFiStaking.sol                   | Staking and accounting core  | Principal, rewards, rates, exits, pause, rescue |
| WhaleCeFiGovernanceController.sol      | 2-of-3 delayed governance    | Scheduling, approvals, execution, cancellation  |
| WhaleCeFiLTVGuard.sol                  | Credit boundary              | Haircut-adjusted LTV <= 80.00%                  |
| WhaleCeFiReserveCommitmentRegistry.sol | Reserve commitment anchor    | Governance-only append-only epochs              |
| Adversarial token set                  | Negative-path execution      | Fee, false-return, callback behavior            |

ASSESSMENT BOUNDARIES

- Included: source review, baseline reproduction, patch mapping, compilation, deterministic local deployment, negative paths, boundary tests, role checks, invariants, registry validation, artifact hashing.
- Operational controls reviewed as models: governance threshold and delay, guardian pause, protected principal, reward surplus, LTV limit, reserve commitment, asset identity.
- Separate assurance domains: complete custody and liability reconciliation, backend and database security, identity/KYC, oracle freshness, bridges, infrastructure, incident operations, legal and regulatory compliance.

# SECURITY ARCHITECTURE

AUTHORITY AND VALUE FLOW



| ACTOR             | AUTHORIZED ACTION             | ENFORCED BOUNDARY                               |
|-------------------|-------------------------------|-------------------------------------------------|
| Governance owners | Approve scheduled operations  | No unilateral configuration                     |
| Guardian          | Pause new stake               | Exit remains open; cannot unpause               |
| User              | Stake and exit positions      | Principal tracked per position and in aggregate |
| Reward funder     | Add reward surplus            | Cannot relabel principal as reward capacity     |
| Registry          | Bind chain, address, decimals | Prevents symbol-only routing                    |

CORE INVARIANTS

- I-01** Contract balance >= totalPrincipal after every completed value-moving operation.
- I-02** Core staking asset cannot pass through the privileged recovery path.
- I-03** LTV > 8,000 bps is rejected before execution.
- I-04** A published reserve epoch cannot be replaced under the same epoch ID.

# METHODOLOGY

05 / METHOD

01

## Evidence control

Hash source, reports, manifests, compiler output, bytecode, and tests.

02

## Baseline reproduction

Translate each reported root cause into the smallest executable failure path.

03

## Patch mapping

Bind every remediation to a contract, function, invariant, and authority boundary.

04

## Adversarial retest

Exercise negative paths, exact boundaries, malicious token behavior, and state sequences.

05

## Closure

Close only when the named build compiles and the mapped verification checks pass.

### CLOSURE RULE

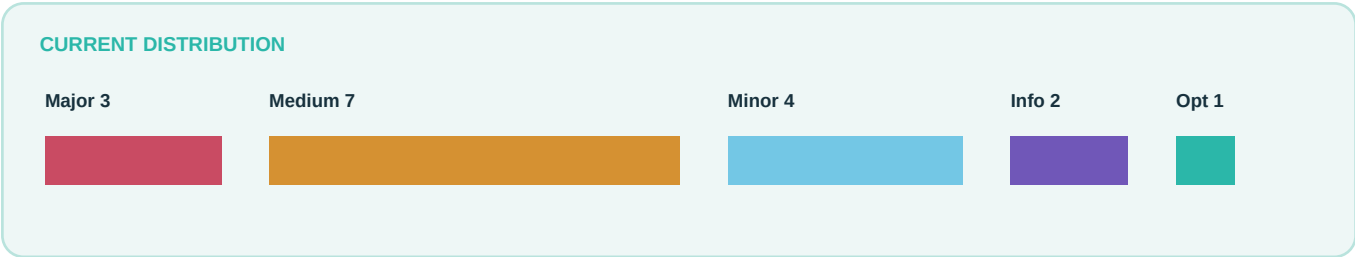
A status changes to Resolved only when (1) the root cause is identified, (2) the patch is present in the exact assessed source, (3) a negative or boundary test exercises the control, (4) the result is bound to compiler and deployment identity, and (5) remaining operational dependencies are recorded.

SEVERITY & STATUS TAXONOMY

06 / TAXONOMY

| SEVERITY      | DEFINITION                                                              | COUNT |
|---------------|-------------------------------------------------------------------------|-------|
| Critical      | Direct loss of funds or complete control under realistic conditions     | 0     |
| Major         | Material loss, governance takeover, insolvency, or credit-limit failure | 3     |
| Medium        | Protocol integrity, accounting, integration, or evidence failure        | 7     |
| Minor         | Lower-impact logic, validation, or token interaction weakness           | 4     |
| Informational | Clarity, units, or deterministic presentation control                   | 2     |
| Optimization  | Configuration integrity or efficiency improvement                       | 1     |

| STATUS       | MEANING                                                                            |
|--------------|------------------------------------------------------------------------------------|
| Acknowledged | Recorded in the baseline assessment without verified code closure in that delivery |
| Reproduced   | Failure condition observed in the controlled baseline                              |
| Resolved     | Root cause patched and mapped verification check passed in the assessed build      |
| Extended     | Control added beyond the original one-file baseline scope                          |



BASELINE FINDING INDEX

07 / FINDINGS

| ID     | FINDING                                  | SEVERITY      | BASELINE     | FINAL    |
|--------|------------------------------------------|---------------|--------------|----------|
| SST-01 | Centralization risks in Stake.sol        | Major         | Acknowledged | Resolved |
| SST-02 | Incompatibility with deflationary tokens | Medium        | Acknowledged | Resolved |
| SST-07 | totalStaked not deducted on exit         | Medium        | Acknowledged | Resolved |
| SST-08 | Core asset drain through withdraw        | Medium        | Acknowledged | Resolved |
| SST-03 | Missing zero-address validation          | Minor         | Acknowledged | Resolved |
| SST-04 | Unsafe integer casts                     | Minor         | Acknowledged | Resolved |
| SST-06 | Incorrect period comparison              | Minor         | Acknowledged | Resolved |
| SST-09 | Unchecked ERC-20 return values           | Minor         | Acknowledged | Resolved |
| SST-05 | Undefined interest-rate decimal          | Informational | Acknowledged | Resolved |
| SST-10 | Token variable could be immutable        | Optimization  | Acknowledged | Resolved |



EXPANDED CONTROL INDEX

| ID     | CONTROL FINDING                          | SEVERITY      | CATEGORY              | FINAL    |
|--------|------------------------------------------|---------------|-----------------------|----------|
| WCF-11 | Protected principal and reward reserve   | Major         | Solvency control      | Resolved |
| WCF-12 | Deterministic 80% LTV boundary           | Major         | Credit risk           | Resolved |
| WCF-13 | Token callback reentrancy                | Medium        | Execution safety      | Resolved |
| WCF-14 | Emergency pause preserves user exits     | Medium        | Incident response     | Resolved |
| WCF-15 | Append-only Proof-of-Reserves commitment | Medium        | Evidence integrity    | Resolved |
| WCF-16 | Chain-aware asset identity               | Medium        | Integration integrity | Resolved |
| UX-01  | Deterministic minor-unit formatting      | Informational | Display integrity     | Resolved |

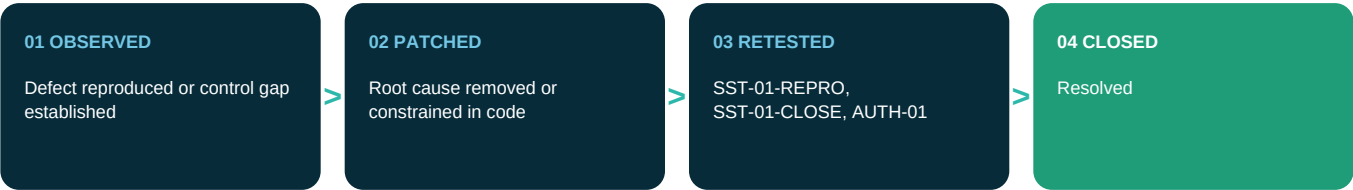
WHY THESE CONTROLS WERE ADDED

The baseline review covered one staking source file. The remediation campaign expanded the assessment to the system properties that determine whether corrected contract logic remains safe when combined with governance, reward funding, credit boundaries, reserve evidence, asset routing, and customer-facing amount representation.

These seven items are not retroactively attributed to the baseline source. They are separately identified, tested, and closed in the assessed build.

# REMEDIATION LIFECYCLE

09 / CLOSURE MODEL



## FINDING EVIDENCE CHAIN

| LAYER         | REQUIRED EVIDENCE                                                                    |
|---------------|--------------------------------------------------------------------------------------|
| Observation   | What fails, under which preconditions, and what asset or authority is affected       |
| Root cause    | The precise state, call, unit, role, or identity assumption that permits the failure |
| Remediation   | The implemented code or architecture change that removes or constrains the cause     |
| Verification  | Named test, boundary values, revert path, state result, compiler, and deployment     |
| Residual risk | Dependencies not eliminated by the source-level patch                                |

### STATUS INTEGRITY

The baseline status is preserved as historical evidence. The final status records the separately tested remediation state. This prevents an acknowledged historical item from being silently rewritten while still allowing the current build to carry a verified closure.

SST-01 / CENTRALIZATION RISKS IN STAKE.SOL

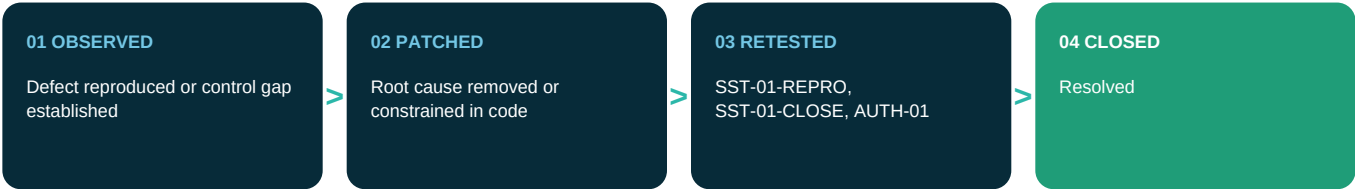
FINDING DETAIL

MAJOR

PRIVILEGE / GOVERNANCE

RESOLVED

Baseline: src/Stake.sol:269,275,281,287,293,491 | Build: GovernanceController.sol:45-119



OBSERVATION

A single owner could modify economic parameters, redirect penalty flows, change ownership, and withdraw arbitrary token balances without a delay or a second approval.

ROOT CAUSE

All privileged actions terminated at one externally owned account and lacked an execution delay, approval threshold, and operation-specific authorization record.

IMPLEMENTED REMEDIATION

Privileged configuration now executes through a 2-of-3 controller. Every operation is bound to chain, controller, nonce, target, value, calldata hash, and salt, then held for at least 172,800 seconds.

VERIFICATION RESULT

One approval cannot execute; a direct owner call reverts; two approvals plus the 48-hour delay apply the exact scheduled parameter change.

RESIDUAL RISK

Signer security, monitoring, and governance key rotation remain operational controls.

SST-02 / INCOMPATIBILITY WITH DEFLATIONARY TOKENS

FINDING DETAIL

MEDIUM

ACCOUNTING

RESOLVED

Baseline: src/Stake.sol:341,345 | Build: WhaleCeFiStaking.sol:154-184



OBSERVATION

The baseline credited the requested amount even when a fee-on-transfer asset delivered less value, creating a ledger deficit that could consume another user's principal.

ROOT CAUSE

Accounting used the function argument rather than the observed balance delta around transferFrom.

IMPLEMENTED REMEDIATION

The remediated stake path snapshots the contract balance before and after transferFrom and reverts atomically unless the observed receipt equals the credited principal.

VERIFICATION RESULT

A 10% transfer fee produced a 10,000-unit deficit in the baseline. The assessed build rejected the same path and preserved the user's balance and totalPrincipal=0.

RESIDUAL RISK

Asset onboarding must continue to classify rebasing, callback, proxy, and non-standard transfer behavior.

# SST-07 / TOTALSTAKED NOT DEDUCTED ON EXIT

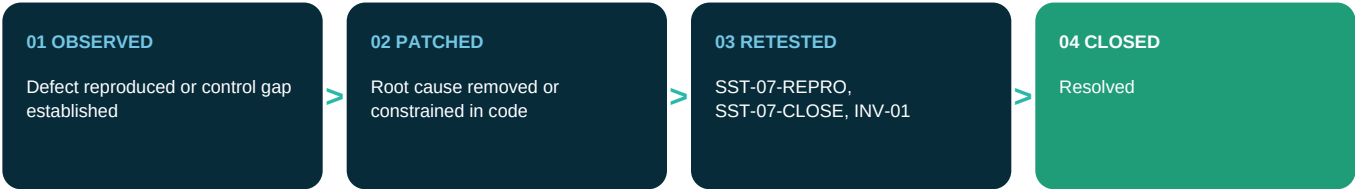
FINDING DETAIL

MEDIUM

ACCOUNTING INVARIANT

RESOLVED

Baseline: src/Stake.sol:381,424 | Build: WhaleCeFiStaking.sol:187-210



OBSERVATION

The aggregate counter remained inflated after exit even though the user's recorded position and contract balance decreased.

ROOT CAUSE

The exit path updated the per-user balance but omitted the corresponding aggregate ledger mutation.

IMPLEMENTED REMEDIATION

Positions close once, totalPrincipal is decremented before external transfers, and the post-transfer balance must remain greater than or equal to outstanding principal.

VERIFICATION RESULT

The baseline diverged by 40,000 units. The assessed build returned aggregate principal to zero and preserved the invariant through a randomized multi-position sequence.

RESIDUAL RISK

Off-chain ledgers and custody books require independent event reconciliation.

SST-08 / CORE ASSET DRAIN THROUGH WITHDRAW

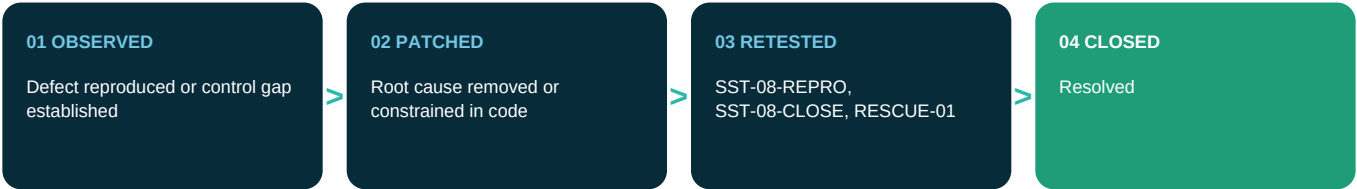
FINDING DETAIL

MEDIUM

ASSET PROTECTION

RESOLVED

Baseline: src/Stake.sol:491 | Build: WhaleCeFiStaking.sol:222-228



OBSERVATION

The privileged withdraw path accepted the staking asset itself, enabling the owner to remove principal backing from the contract.

ROOT CAUSE

The recovery function did not separate recoverable foreign tokens from the protected core asset.

IMPLEMENTED REMEDIATION

rescueForeignToken rejects the immutable staking token and executes foreign-token recovery only through delayed threshold governance.

VERIFICATION RESULT

The baseline drained 60,000 units. Core-asset rescue now reverts, while a foreign token can be recovered only after two approvals and the mandatory delay.

RESIDUAL RISK

Custodial assets outside the contract require separate withdrawal policy and segregation controls.

SST-03 / MISSING ZERO-ADDRESS VALIDATION

FINDING DETAIL

MINOR

INPUT VALIDATION

RESOLVED

Baseline: src/Stake.sol:90,294 | Build: WhaleCeFiStaking.sol:103-117



**OBSERVATION**

Critical token and authority fields could be initialized or updated to address(0), creating unusable calls or unrecoverable authority state.

**ROOT CAUSE**

Constructors and role setters trusted address inputs without semantic validation.

**IMPLEMENTED REMEDIATION**

The constructor and every authority update reject the zero address before changing state. The staking token is assigned once and is immutable.

**VERIFICATION RESULT**

The baseline deployed with a zero token. The remediated constructor reverted before deployment and no state or funds moved.

**RESIDUAL RISK**

A non-zero address must still be checked for expected code, owner, proxy state, and chain.

MINOR

NUMERIC SAFETY

RESOLVED

Baseline: src/Stake.sol:189-192,219-222,304-324 | Build: WhaleCeFiStaking.sol:247-256



**OBSERVATION**

Narrowing casts could truncate high-order bits and persist a principal, timestamp, or maturity value different from the value supplied by the caller.

**ROOT CAUSE**

Direct uint96 and other narrowing conversions were used without an explicit upper-bound check.

**IMPLEMENTED REMEDIATION**

Checked conversion helpers compare each value against the destination type maximum and revert before storage or token movement on overflow.

**VERIFICATION RESULT**

Casting  $2^{96}+7$  produced 7 in the baseline. Principal above uint128 now reverts and preserves the user's balance.

RESIDUAL RISK

Future storage-layout changes must repeat bound analysis and migration tests.



# SST-06 / INCORRECT PERIOD COMPARISON

FINDING DETAIL

MINOR

BUSINESS LOGIC

RESOLVED

Baseline: src/Stake.sol:359 | Build: WhaleCeFiStaking.sol:154-184,243-245



OBSERVATION

The baseline accepted an equal period where the intended rule required a strictly stronger or separately validated position term.

ROOT CAUSE

Ambiguous enum ordering was treated as a complete policy rule for restaking.

IMPLEMENTED REMEDIATION

The ambiguous restake entry point was removed. Every new position validates one of the explicit supported durations: 30, 90, 180, or 365 days.

VERIFICATION RESULT

The baseline accepted currentPeriod=3 and nextPeriod=3. The remediated ABI contains no restake function and requires a newly validated position.

RESIDUAL RISK

Product-level rollover rules should be specified and tested before reintroduction.

# SST-09 / UNCHECKED ERC-20 RETURN VALUES

FINDING DETAIL

MINOR

TOKEN INTERACTION

RESOLVED

Baseline: src/Stake.sol:345,415,416,455,486,493 | Build: WhaleCeFiStaking.sol:9-25



OBSERVATION

A token returning false could leave the internal ledger updated even though no transfer occurred.

ROOT CAUSE

The baseline ignored the boolean return value from transfer and transferFrom.

IMPLEMENTED REMEDIATION

The token wrapper requires call success and either an empty return payload or an ABI-decoded true value; all other outcomes revert.

VERIFICATION RESULT

The baseline credited 25,000 units while receiving zero. The assessed path rejected the false return and retained totalPrincipal=0.

RESIDUAL RISK

Token proxy upgrades and blacklist controls remain integration risks.

# SST-05 / UNDEFINED INTEREST-RATE DECIMAL

[FINDING DETAIL](#)

INFORMATIONAL

ECONOMIC UNITS

RESOLVED

Baseline: src/Stake.sol:275,321 | Build: WhaleCeFiStaking.sol:54-56,119-124



OBSERVATION

The stored interest-rate value had no enforced denominator, allowing integrators to interpret the same integer as percent, basis points, or another scale.

ROOT CAUSE

Economic units were implicit documentation rather than an executable invariant.

IMPLEMENTED REMEDIATION

Rates and penalties use integer basis points with BPS\_DENOMINATOR=10,000 and hard maximums of 5,000 reward bps and 2,000 penalty bps.

VERIFICATION RESULT

The baseline accepted an unbounded value with no unit. The assessed build enforces denominator, bounds, and term-specific values.

RESIDUAL RISK

Displayed annualized rates must preserve the same unit and rounding convention end to end.

SST-10 / TOKEN VARIABLE COULD BE IMMUTABLE

FINDING DETAIL

OPTIMIZATION

CONFIGURATION INTEGRITY

RESOLVED

Baseline: src/Stake.sol:66 | Build: WhaleCeFiStaking.sol:58,103-117



OBSERVATION

A token address that never changes after construction was stored as a mutable state variable.

ROOT CAUSE

The declaration did not encode the intended single-assignment property.

IMPLEMENTED REMEDIATION

stakingToken is public immutable and assigned only after constructor validation.

VERIFICATION RESULT

The compiled source contains one immutable staking-token assignment and no setter in the ABI.

RESIDUAL RISK

A token migration requires a new deployment and an explicit user migration process.

WCF-11 / PROTECTED PRINCIPAL AND REWARD RESERVE

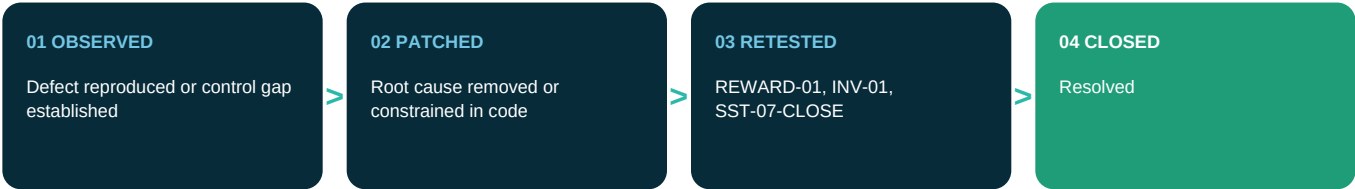
FINDING DETAIL

MAJOR

SOLVENCY CONTROL

RESOLVED

WhaleCeFiStaking.sol:187-220,238-241



OBSERVATION

A staking contract can appear solvent while paying rewards from principal unless outstanding principal and reward surplus are separated by an executable rule.

ROOT CAUSE

A raw token balance alone does not distinguish user principal from the amount available for rewards.

IMPLEMENTED REMEDIATION

totalPrincipal tracks protected principal. Mature exit requires balance >= totalPrincipal + reward, and availableRewardReserve exposes only balance minus principal.

VERIFICATION RESULT

A 100,000-unit principal paid a separately funded 1,000-unit reward; principal returned to zero and the invariant held across the randomized sequence.

RESIDUAL RISK

The contract invariant does not replace complete platform liability and custody reconciliation.

WCF-12 / DETERMINISTIC 80% LTV BOUNDARY

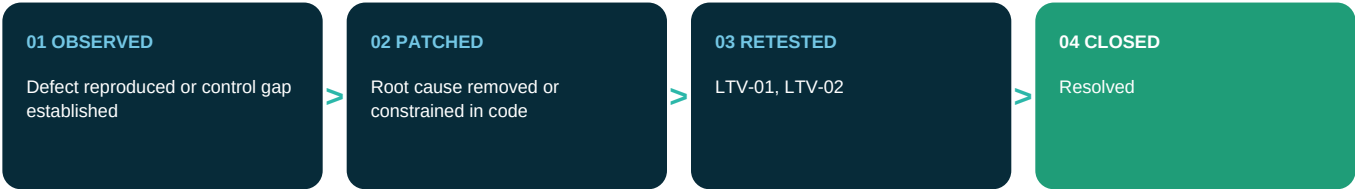
FINDING DETAIL

MAJOR

CREDIT RISK

RESOLVED

WhaleCeFiLTVGuard.sol:11-31



OBSERVATION

An off-by-one or floating-point LTV calculation can approve debt above the policy ceiling at the exact liquidation boundary.

ROOT CAUSE

Credit limits become ambiguous when haircut application, denominator, and inclusivity are not encoded together.

IMPLEMENTED REMEDIATION

The guard applies the haircut first, calculates integer basis-point LTV, accepts  $\leq 8,000$  bps, and rejects  $> 8,000$  bps before execution.

VERIFICATION RESULT

79.99% and 80.00% were accepted; 80.01% reverted with LTVExceeded.

RESIDUAL RISK

Price freshness, oracle manipulation, collateral liquidity, and liquidation execution remain separate controls.

WCF-13 / TOKEN CALLBACK REENTRANCY

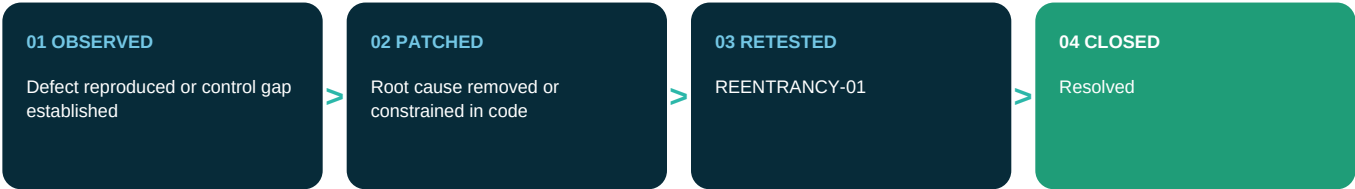
FINDING DETAIL

MEDIUM

EXECUTION SAFETY

RESOLVED

WhaleCeFiStaking.sol:96-101,154-184,187-228



OBSERVATION

A malicious token can attempt to call stake again during transferFrom and interfere with position or aggregate accounting.

ROOT CAUSE

External token calls create a callback boundary inside a value-changing operation.

IMPLEMENTED REMEDIATION

All value-moving entry points share one reentrancy state guard, and accounting follows checks-effects-interactions ordering.

VERIFICATION RESULT

The adversarial callback was attempted but did not re-enter; exactly 10,000 units were credited once.

RESIDUAL RISK

New external integrations must join the same call-graph and reentrancy analysis.

WCF-14 / EMERGENCY PAUSE PRESERVES USER EXITS

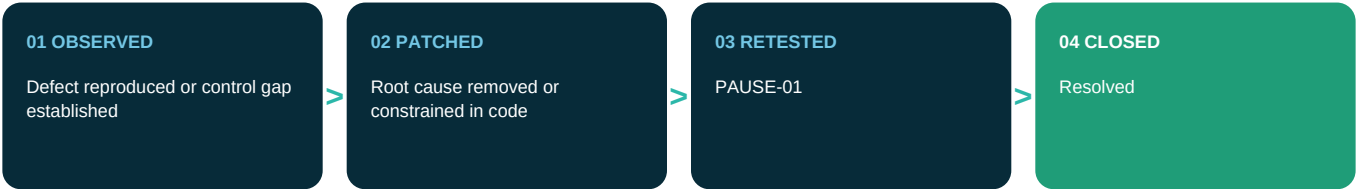
FINDING DETAIL

MEDIUM

INCIDENT RESPONSE

RESOLVED

WhaleCeFiStaking.sol:91-94,144-152,187-211



OBSERVATION

A global pause that blocks exits can turn incident containment into an involuntary lock of user principal.

ROOT CAUSE

Pause policy was not separated by action type and authority.

IMPLEMENTED REMEDIATION

The guardian can pause new stake immediately; exit remains callable. Only delayed threshold governance can unpause.

VERIFICATION RESULT

Stake reverted while paused, exit remained available, and unpause authority resolved to the governance controller.

RESIDUAL RISK

A compromised guardian can interrupt deposits until governance responds.



WCF-15 / APPEND-ONLY PROOF-OF-RESERVES COMMITMENT

FINDING DETAIL

MEDIUM

EVIDENCE INTEGRITY

RESOLVED

WhaleCeFiReserveCommitmentRegistry.sol:18-56



OBSERVATION

A reserve publication loses evidentiary value if a published epoch can be overwritten, replayed across domains, or emitted without liability and reserve digests.

ROOT CAUSE

Mutable epoch storage and incomplete domain separation allow ambiguous history.

IMPLEMENTED REMEDIATION

Each epoch stores merkle root, liability digest, reserve digest, cutoff, and publication time under a domain-separated, governance-only, append-only key.

VERIFICATION RESULT

Governance publication succeeded after delay; an overwrite of the same epoch reverted and the original commitment remained unchanged.

RESIDUAL RISK

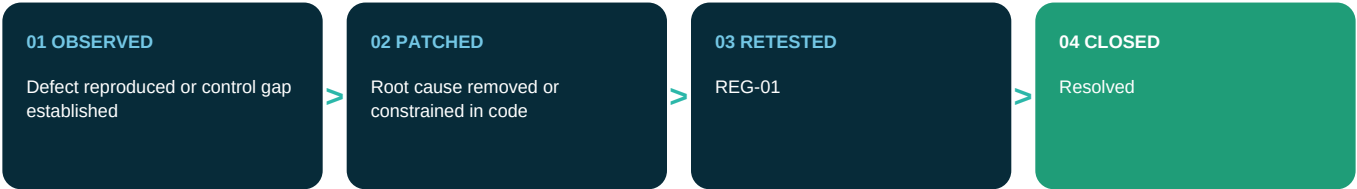
Commitment integrity does not independently establish reserve ownership, valuation, encumbrance, or liability completeness.

MEDIUM

INTEGRATION INTEGRITY

RESOLVED

evidence/external\_asset\_registry.json



OBSERVATION

A token symbol or bare address is ambiguous across chains, bridges, native assets, and custodial labels.

ROOT CAUSE

Asset identity lacked a canonical tuple of chain, address, checksum, and decimals.

IMPLEMENTED REMEDIATION

The registry binds 18 EVM contracts to chain IDs, checksummed addresses, and decimals; 11 native routes remain explicitly addressless; one prohibited identifier is rejected.

VERIFICATION RESULT

All 18 contract identities were unique by chain/address tuple and all 11 native routes passed the addressless invariant.

RESIDUAL RISK

Proxy implementations and enabled-route allowlists require refresh when dependencies upgrade.

UX-01 / DETERMINISTIC MINOR-UNIT FORMATTING

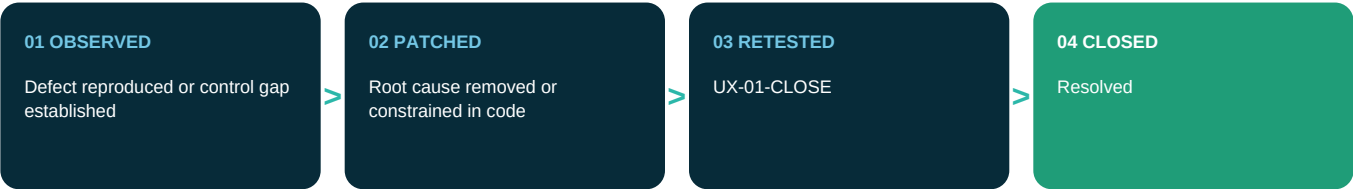
FINDING DETAIL

INFORMATIONAL

DISPLAY INTEGRITY

RESOLVED

scripts/compile\_and\_test.mjs:553-576



OBSERVATION

Floating-point conversion can display a customer amount differently from the integer value used by the contract or ledger.

ROOT CAUSE

Presentation logic often converts exact integer minor units through binary floating point.

IMPLEMENTED REMEDIATION

Formatting uses signed integer arithmetic, asset decimals, zero padding, and deterministic string assembly.

VERIFICATION RESULT

Six vectors across 6, 8, 9, and 18 decimals, including a negative minor unit, matched exact canonical strings without floating point.

RESIDUAL RISK

Every customer-facing surface must reuse the same decimal metadata and rounding policy.

AUTOMATED REVALIDATION CAMPAIGN

10 / VERIFICATION

31

TOTAL CHECKS

31

PASSED

0

FAILED

| CAMPAIGN              | CHECKS    | COVERAGE                                                                    |
|-----------------------|-----------|-----------------------------------------------------------------------------|
| Compilation           | CMP-01    | 9 Solidity sources / zero errors / zero warnings                            |
| Baseline reproduction | 9 REPRO   | Privilege, accounting, token, cast, period, unit defects                    |
| Mapped closure        | 10 CLOSE  | All baseline findings mapped to patch behavior                              |
| Expanded controls     | 11 checks | Auth, reentrancy, pause, rewards, invariant, rescue, LTV, PoR, registry, UX |

EXECUTION IDENTITY

| FIELD              | VALUE                                   |
|--------------------|-----------------------------------------|
| Solidity           | 0.8.26+commit.8a97fa7a.Emscripten.clang |
| Optimizer          | Enabled / 200 runs                      |
| EVM                | Shanghai                                |
| Chain              | 31337 / block 82                        |
| Deployed contracts | 9                                       |

## TEST RESULT REGISTER 1/2

11 / VERIFICATION

| TEST ID      | STATUS | ASSERTION                                                                    | EVIDENCE EXTRACT                                                 |
|--------------|--------|------------------------------------------------------------------------------|------------------------------------------------------------------|
| CMP-01       | PASS   | All assessment sources compile without Solidity errors                       | compiler=0.8.26+commit.8a97fa7a.Emscripten.clang; source_count=9 |
| SST-07-REPRO | PASS   | Baseline totalStaked remains inflated after unstake                          | totalStaked=100000; userStake=60000                              |
| SST-08-REPRO | PASS   | Baseline owner can drain the core staking token                              | drained=60000;<br>destination=0xf39Fd6e51aad88F6F4ce6            |
| SST-02-REPRO | PASS   | Baseline credits requested amount instead of fee-adjusted receipt            | credited=100000; received=90000                                  |
| SST-09-REPRO | PASS   | Baseline credits stake even when transferFrom returns false                  | credited=25000; received=0                                       |
| SST-03-REPRO | PASS   | Baseline accepts a zero token address                                        | deployment=0x610178dA211FEF7D417bC0e6FeD39F05609AD788;           |
| SST-04-REPRO | PASS   | Baseline uint96 cast truncates high bits                                     | input=79228162514264337593543950343; output=7                    |
| SST-01-REPRO | PASS   | Baseline owner can set unconstrained privileged parameters                   | owner=0xf39Fd6e51aad88F6F4ce6aB8827279cFFb92266;                 |
| SST-06-REPRO | PASS   | Baseline restake check accepts an equal period                               | currentPeriod=3; nextPeriod=3                                    |
| SST-05-REPRO | PASS   | Baseline accepts an interest-rate value without a declared unit bound        | storedValue=1; enforcedUnit=None                                 |
| SST-01-CLOSE | PASS   | 2-of-3 governance and 48-hour delay replace unilateral configuration         | threshold=2-of-3;<br>minDelaySeconds=172800                      |
| AUTH-01      | PASS   | Externally owned governance signer cannot bypass the controller              | revert=missing revert data;<br>governance=0x9A676e781A523b5d0C0  |
| SST-02-CLOSE | PASS   | Remediated build rejects fee-on-transfer accounting divergence atomically    | revert=missing revert data;<br>userBalancePreserved=900000       |
| SST-09-CLOSE | PASS   | Assessment safe-transfer wrapper rejects a false ERC-20 return value         | revert=missing revert data;<br>totalPrincipal=0                  |
| SST-03-CLOSE | PASS   | Assessment constructor rejects every zero-address authority or token         | revert=missing revert data                                       |
| SST-04-CLOSE | PASS   | Assessment checked cast rejects principal above uint128 without moving funds | attemptedPrincipal=340282366920938463463374607431768211456;      |

## TEST RESULT REGISTER 2/2

11 / VERIFICATION

| TEST ID       | STATUS | ASSERTION                                                                   | EVIDENCE EXTRACT                                                            |
|---------------|--------|-----------------------------------------------------------------------------|-----------------------------------------------------------------------------|
| SST-05-CLOSE  | PASS   | Assessment reward unit is bounded integer basis points                      | denominator=10000;<br>maximumRewardBps=5000                                 |
| SST-06-CLOSE  | PASS   | Ambiguous restake entry point is absent from the remediated ABI             | restakeFunctionsPresent=False;<br>replacement=new independently             |
| SST-10-CLOSE  | PASS   | Staking token identity is immutable in the remediated source                | declaration=address public immutable<br>stakingToken                        |
| REENTRANCY-01 | PASS   | Adversarial token callback cannot re-enter stake                            | callbackAttempted=True;<br>callbackSucceeded=False                          |
| PAUSE-01      | PASS   | Emergency pause blocks new stake but preserves user exit path               | stakeRevert=missing revert data;<br>exitGatedByPause=False                  |
| SST-07-CLOSE  | PASS   | Principal accounting decrements before external transfers and remains exact | beforeExit=100000; afterExit=0                                              |
| REWARD-01     | PASS   | Mature reward payment requires surplus above protected principal            | principal=100000; reward=1000                                               |
| INV-01        | PASS   | Randomized position sequence preserves totalPrincipal invariant             | operations=10; finalTotalPrincipal=0                                        |
| SST-08-CLOSE  | PASS   | Core staking asset cannot be rescued through the privileged recovery path   | revert=transaction execution reverted;<br>coreToken=0x5FbDB2315678afecb367f |
| RESCUE-01     | PASS   | Foreign tokens can be recovered only through delayed threshold governance   | recovered=12345;<br>recipient=0x976EA74026E726554dB65                       |
| LTV-01        | PASS   | LTV guard accepts 79.99% and exactly 80.00%                                 | acceptedBps=[7999, 8000]                                                    |
| LTV-02        | PASS   | LTV guard rejects 80.01% before execution                                   | rejectedBps=8001;<br>revert=LTVExceeded                                     |
| POR-01        | PASS   | PoR epoch commitment is governance-only, delayed, and append-only           | unauthorized=missing revert data;<br>duplicateRevert=transaction execution  |
| REG-01        | PASS   | External registry binds every EVM address to a unique chain and checksum    | externalContracts=18; nativeRoutes=11                                       |
| UX-01-CLOSE   | PASS   | Minor-unit formatting is deterministic across asset precisions              | vectorCount=6;<br>canonicalSource=integer minor units                       |

REVALIDATION DEPLOYMENT IDENTITY

12 / DEPLOYMENT

| CONTRACT                           | ADDRESS                                    | RUNTIME SHA-256                 |
|------------------------------------|--------------------------------------------|---------------------------------|
| MockERC20                          | 0x5FbDB2315678afecb367f032d93F642f64180aa3 | 929358745f9e9c2b941b3886<br>... |
| StakeBaseline                      | 0x9fE46736679d2D9a65F0992F2272dE9f3c7fa6e0 | ea80a76d211f6d10c31db040<br>... |
| FeeOnTransferToken                 | 0xDc64a140Aa3E981100a9becA4E685f962f0cF6C9 | 8167b34608e17ab044ae139<br>9... |
| FalseReturnToken                   | 0xa513E6E4b8f2a923D98304ec87F64353C4D5C853 | 8497f861ea3e53147a75c34b<br>... |
| WhaleCeFiGovernanceController      | 0x9A676e781A523b5d0C0e43731313A708CB607508 | 92e07c16e84b5d93e9a6366<br>2... |
| WhaleCeFiStaking                   | 0x0B306BF915C4d645ff596e518fAf3F9669b97016 | 08ad28b70abfd8384a5ce129<br>... |
| ReentrantToken                     | 0x4ed7c70F96B99c776995fB64377f0d4aB3B0e1C1 | f2908615b4d93eb6db7c070a<br>... |
| WhaleCeFiLTVGuard                  | 0x851356ae760d987E095750cCeb3bC6014560891C | e4ce2f22172c1470e632e023<br>... |
| WhaleCeFiReserveCommitmentRegistry | 0xf5059a5D33d5853360D16C683c16e67980206f36 | 54cf14eaa09c308e8ea8b222<br>... |

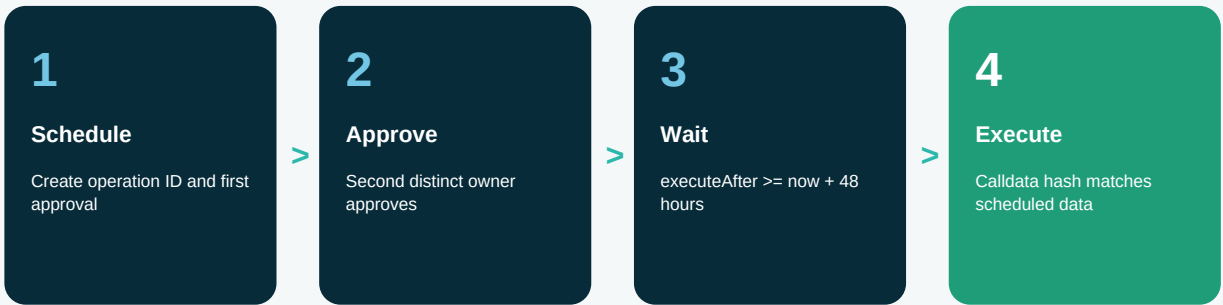
ENVIRONMENT BINDING

Chain ID 31337; Whale CeFi isolated revalidation environment; latest assessed block 82; Solidity 0.8.26+commit.8a97fa7a.Emscripten.clang; optimizer 200; Shanghai EVM. Address meaning is inseparable from this chain and bytecode identity.

GOVERNANCE & PRIVILEGED OPERATIONS

| CONTROL           | VALUE     | SECURITY EFFECT                                              |
|-------------------|-----------|--------------------------------------------------------------|
| Owners            | 3         | 0xf39F...2266 / 0x7099...79C8 / 0x3C44...93BC                |
| Threshold         | 2         | No operation executes with one approval                      |
| Delay             | 172,800 s | Minimum 48 hours between schedule and execution              |
| Operation binding | Full      | Chain, controller, nonce, target, value, calldata hash, salt |
| Guardian          | 1 role    | May pause new stake; cannot unpause or move funds            |
| Cancellation      | Owner     | Scheduled operation can be cancelled before execution        |

PRIVILEGED OPERATION LIFECYCLE





PRINCIPAL & REWARD ACCOUNTING

PROTECTED-BALANCE EQUATION

$$\text{contractBalance} \geq \text{totalPrincipal}$$
$$\text{availableRewardReserve} = \max(\text{balance} - \text{principal}, 0)$$

| OPERATION      | PRINCIPAL DELTA | ENFORCED RULE                                                 |
|----------------|-----------------|---------------------------------------------------------------|
| Stake          | + received      | Observed balance delta must equal requested amount            |
| Early exit     | - principal     | Penalty routed separately; aggregate decremented before calls |
| Mature exit    | - principal     | Reward allowed only from surplus above protected principal    |
| Reward funding | No change       | Increases token balance but not totalPrincipal                |
| Foreign rescue | No change       | Core token explicitly forbidden                               |

VERIFICATION EVIDENCE

SST-07-CLOSE: beforeExit=100000, afterExit=0, earlyExitPenalty=7000. REWARD-01: principal=100000, reward=1000, paid=101000, principalAfter=0. INV-01: ten operations across five position sizes completed with finalTotalPrincipal=0.

LTV CONTROL MODEL

15 / CREDIT RISK

POLICY EQUATION

$$\text{adjustedCollateral} = \text{collateral} * (10000 - \text{haircutBps}) / 10000$$
$$\text{LTV\_bps} = \text{debt} * 10000 / \text{adjustedCollateral}$$

ACCEPT IFF LTV\_bps <= 8000

| OBSERVED | INTEGER VALUE | DECISION           | TEST   |
|----------|---------------|--------------------|--------|
| 79.99%   | 7,999 bps     | ACCEPT             | LTV-01 |
| 80.00%   | 8,000 bps     | ACCEPT             | LTV-01 |
| 80.01%   | 8,001 bps     | REVERT LTVExceeded | LTV-02 |

CONTROL SEQUENCE

- 1 Validate collateral > 0 and haircut <= 5,000 bps
- 2 Apply haircut using checked integer arithmetic
- 3 Calculate LTV in basis points
- 4 Reject values above 8,000 before downstream execution

PROOF-OF-RESERVES EVIDENCE MODEL

| FIELD           | TYPE    | PURPOSE                           |
|-----------------|---------|-----------------------------------|
| epochId         | bytes32 | Unique publication key            |
| merkleRoot      | bytes32 | Customer proof tree root          |
| liabilityDigest | bytes32 | Complete liability-set commitment |
| reserveDigest   | bytes32 | Reserve evidence-set commitment   |
| cutoff          | uint64  | Measurement time                  |
| publishedAt     | uint64  | On-chain publication time         |

PUBLICATION CONTROLS

|                  |                                                                                |
|------------------|--------------------------------------------------------------------------------|
| Governance-only  | Registry accepts publication only from the delayed controller.                 |
| Domain-separated | WHALE_CEFI_POR_ASSESSMENT_V1 prevents cross-protocol interpretation.           |
| Append-only      | An existing epoch ID cannot be overwritten or replayed.                        |
| Complete tuple   | Root, liabilities, reserves, cutoff, and publication time are stored together. |
| Retest           | POR-01 published after approval and delay, then rejected the overwrite.        |

EXTERNAL ASSET IDENTITY REGISTRY 1/2

17 / ASSET IDENTITY

| ASSET ID    | CHAIN | CHECKSUMMED ADDRESS                        | DEC  |
|-------------|-------|--------------------------------------------|------|
| CBETH-ETH   | 1     | 0xBe9895146f7AF43049ca1c1AE358B0541Ea49704 | 18   |
| RETH-ETH    | 1     | 0xae78736Cd615f374D3085123A210448E74Fc6393 | 18   |
| STETH-ETH   | 1     | 0xae7ab96520DE3A18E5e111B5EaAb095312D7fE84 | 18   |
| WSTETH-ETH  | 1     | 0x7f39C581F595B53c5cb19bD0b3f8dA6c935E2Ca0 | 18   |
| LIDO-WQ-ETH | 1     | 0x889edC2eDab5f40e902b864aD4d7AdE8E412F9B1 | None |
| USDC-ETH    | 1     | 0xA0b86991c6218b36c1d19D4a2e9Eb0cE3606eB48 | 6    |
| 1INCH-ETH   | 1     | 0x111111111117dC0aa78b770fA6A738034120C302 | 18   |
| ARB-ARB1    | 42161 | 0x912CE59144191C1204E64559FE8253a0e49E6548 | 18   |
| CAKE-BSC    | 56    | 0x0E09FaBB73Bd3Ade0a17ECC321fD13a19e81cE82 | 18   |

REGISTRY INVARIANT

An EVM asset is identified by chain ID, checksummed contract address, and decimals. Symbols and protocol names are display metadata and do not replace this tuple.

## 17 / ASSET IDENTITY

**REGISTRY INVARIANT**

An EVM asset is identified by chain ID, checksummed contract address, and decimals. Symbols and protocol names are display metadata and do not replace this tuple.

NATIVE ROUTES & REJECTED IDENTIFIER

18 / ASSET IDENTITY

| ASSET ID    | NETWORK                   | CONTRACT      | DEC |
|-------------|---------------------------|---------------|-----|
| ADA-CARDANO | Cardano Mainnet           | native / none | 6   |
| AVAX-C      | Avalanche C-Chain / 43114 | native / none | 18  |
| BNB-BSC     | BNB Smart Chain / 56      | native / none | 18  |
| DOGE-DOGE   | Dogecoin Mainnet          | native / none | 8   |
| ETH-ETH     | Ethereum / 1              | native / none | 18  |
| ETH-ARB1    | Arbitrum One / 42161      | native / none | 18  |
| ETH-OP      | OP Mainnet / 10           | native / none | 18  |
| ETH-BASE    | Base / 8453               | native / none | 18  |
| POL-POS     | Polygon PoS / 137         | native / none | 18  |
| SOL-SOLANA  | Solana Mainnet Beta       | native / none | 9   |
| XRP-XRPL    | XRP Ledger Mainnet        | native / none | 6   |

REJECTED IDENTIFIER

0x28C6c06298d514Db089934071355E5743bf21d60

Publicly identified as Binance 14; prohibited as a Whale CeFi or Pulpo treasury identifier.

SOURCE & ARTIFACT INTEGRITY

19 / INTEGRITY

| ARTIFACT                                         | SHA-256                             |
|--------------------------------------------------|-------------------------------------|
| contracts/StakeBaseline.sol                      | 404018947f172ede18fbc461f63bb7f5... |
| contracts/WhaleCeFiGovernanceController.sol      | 872b09d7f5e791bdf50944bff07d0d6b... |
| contracts/WhaleCeFiLTVGuard.sol                  | f4f83de4548f8b3663fd37e7f61e162a... |
| contracts/WhaleCeFiReserveCommitmentRegistry.sol | b9d0144859fb74521e15f0a43b2dc453... |
| contracts/WhaleCeFiStaking.sol                   | 6e1f1b97ae780b03d9fdf6f221c3d3c5... |
| contracts/mocks/FalseReturnToken.sol             | 4e7560de3bd01a2684ab1ee60727acee... |
| contracts/mocks/FeeOnTransferToken.sol           | 8ac72fd0c1aa9593e5906d13a7bb5c77... |
| contracts/mocks/MockERC20.sol                    | 31fb1889e68e0643212331ac374428f6... |
| contracts/mocks/ReentrantToken.sol               | b3c2dec900215f691aeb18ebbe09c874... |
| package.json                                     | 7e6760687720154f50695bb550508d8c... |
| scripts/compile_and_test.mjs                     | 31a66dfc66828a840a52361076d50435... |

INTEGRITY CHAIN

| FIELD              | VALUE                                       |
|--------------------|---------------------------------------------|
| Source files       | 9                                           |
| Compiled artifacts | 10                                          |
| Compiler messages  | 0 errors / 0 warnings                       |
| Evidence manifest  | 86a4176d2dda1aa9d393489f90f0a54d30e672d1... |

THREAT MODEL & RESIDUAL RISK

20 / RESIDUAL RISK

| DOMAIN     | THREAT                         | IMPLEMENTED CONTROL                  | RESIDUAL               |
|------------|--------------------------------|--------------------------------------|------------------------|
| Governance | Signer compromise or collusion | 2-of-3 threshold + 48-hour delay     | Key operations         |
| Token      | Fee, false return, callback    | Balance delta + safe wrapper + guard | Proxy upgrades         |
| Accounting | Principal/reward mixing        | Protected totalPrincipal invariant   | External ledger        |
| Credit     | Boundary error                 | Integer LTV guard                    | Oracle/liquidity       |
| PoR        | Epoch overwrite                | Append-only commitment               | Ownership/completeness |
| Identity   | Wrong chain/address            | Chain-aware registry                 | Dependency changes     |
| Operations | Pause misuse                   | Exit-preserving pause                | Guardian availability  |

HIGHEST-PRIORITY RESIDUAL WORK

- R-01

Map exact live proxy, implementation, admin, timelock, and treasury identities before deployment assurance.
- R-02

Reconcile custodian and on-chain assets against the complete customer liability ledger at one cutoff.
- R-03

Validate oracle freshness, liquidation execution, backend authorization, and database event reconciliation.
- R-04

Operate signer monitoring, incident response, and controlled upgrade procedures.



FINAL ASSESSMENT CONCLUSION

21 / CONCLUSION

17/17

RESOLVED

31/31

PASSED

0

OPEN

CONCLUSION

The remediation verification completed on August 10, 2026 established closure of every finding listed in this report for the exact assessed source and isolated deployment identity. The result is supported by compiler output, nine deployed contract identities, runtime bytecode hashes, 31 passing checks, source and integrity manifests, and finding-by-finding evidence chains.

No finding remains Open, Unresolved, Partially Resolved, or Mitigated in the assessed build. Residual risks are operational and integration domains enumerated on page 40 and do not alter the recorded source-level closure status.

| RECORD           | VALUE                                                              |
|------------------|--------------------------------------------------------------------|
| Prepared by      | Whale CeFi Security Engineering                                    |
| Review functions | Smart Contract Security / Protocol Risk / Verification Engineering |
| Assessment ID    | WCF-SARV-2026-0810                                                 |
| Completion date  | 2026-08-10                                                         |

# EVIDENCE INDEX

22 / EVIDENCE

| EVIDENCE ITEM                        | CONTENTS                                                            |
|--------------------------------------|---------------------------------------------------------------------|
| contracts/                           | 9 Solidity sources including adversarial tokens                     |
| artifacts/                           | ABI, creation bytecode, runtime bytecode, compiler settings, hashes |
| compiler-report.json                 | Compiler version, errors, warnings, artifact summary                |
| deployment-manifest.local-31337.json | Addresses, roles, block, chain, runtime hashes                      |
| test-results.json                    | 31 named checks with machine-readable evidence                      |
| external_asset_registry.json         | 18 EVM contracts, 11 native routes, rejected identifier             |
| source-manifest.sha256               | Source and verification-script hashes                               |
| integrity-manifest.sha256            | Complete evidence-package integrity map                             |
| package.json / lock                  | Pinned ethers, Ganache, and Solidity dependencies                   |
| scripts/compile_and_test.mjs         | Compilation, deployment, differential testing, evidence generation  |

## REPRODUCTION COMMAND

**npm ci**

Install pinned dependencies

**npm run verify**

Compile, deploy, execute checks, and regenerate manifests